

SOH_DID 사전 요청 자료 작성안

작성일: 2026-09-17 | 소스코드 기반 검토본

검토 기준 커밋: 9f31eee2ca7a4261279074fd46859e0e74b2a73e

원본: 「사전 요청 자료 목록(기업 작성용).pdf」 3쪽, 1-51번 항목.

이 문서는 원본의 항목 번호에 대응하는 기업 입력란 답변 초안과 기술 별첨이다. 코드에서 확인된 동작을 작성했으며, 운영환경·조직·정책의 실제 보유 여부는 확정하지 않았다. '저장소에서 미확인'은 기업의 '미보유'를 의미하지 않는다. 외부 서비스와 운영 DB에 접속하거나 실제 거래를 발생시키지 않았다. 비밀키·API 토큰·DB 비밀번호·실제 이용자 식별 값은 수록하지 않았다.

1. 원본 항목별 답변

1-6. 기본 정보

- 조직도:** 기업 확인 필요. 부서 구성, CPO/정보보호 담당자의 직위·부서, 개인정보 취급 부서가 표시된 조직도를 별도 확보해야 한다.
- 임직원 수:** 기업 확인 필요. 정규직·비정규직 인원은 소스코드로 확인할 수 없다.
- 개발자/기술 인력 수:** 기업 확인 필요. 블록체인·백엔드·프론트엔드 담당 인원 구분이 필요하다.
- 보안 전담 인력 수:** 기업 확인 필요. 전담·겸직 여부와 인원을 확인해야 한다.
- 정보보호/개인정보보호 담당자:** 기업 확인 필요. 지정 여부와 직위를 확인해야 한다.
- 24x7 운영/관제:** 기업 확인 필요. 서비스 자동 재시작 설정은 있으나 상시 관제 인력·체계의 증거는 아니다.

7-14. 서비스·기술 구성

- 블록체인 서비스 개요:** 프로젝트명 SOH_DID. 로컬 DID 생성·조회·삭제, VC 발급·검증, VP 생성·검증, 대구체인 연계 지갑 생성, 토큰 생성·전송·회수·잔액 조회를 제공하는 Python Flask API이다. 영상별 토큰 지급 여부를 관리하는 DB 필드와 영상 시청 테스트 화면이 포함되어 있다. 공식 서비스명, 출시일, 실제 사용자 수는 기업 확인 필요. 근거: S1-S5, S7, S9.
- 블록체인 유형/플랫폼:** 대구체인(DChain)의 Mitum 경로 API를 연계한다. 기본 체인 설정값은 minic이며 기본 API 주소는 <https://www.daegu.go.kr/daeguchain/v2/mitum>이다. DID는 애플리케이션에서 did:key 형식으로 별도 생성한다. 퍼블릭/프라이빗/컨소시엄 구분 및 실제 연결망은 기업·체인 운영기관 확인 필요. 근거: S2, S6.
- 서비스 운영 단계:** 코드 및 EC2 배포 예시는 확인되지만, 메인넷 운영/테스트넷/출시 예정 여부는 기업 확인 필요. 근거: S8.
- 스마트컨트랙트 운영 여부/개수:** 외부 DChain API를 통한 토큰 생성, 컨트랙트 주소 저장, 전송·승인·발행·소각 요청 기능이 있다. 저장소에서 자체 컨트랙트 소스·컴파일러·빌드 설정은 확인되지 않았다. 실제 배포 수와 자체 개발 여부는 별도 확인 필요. 로컬 Token 테이블 건수만으로 실제 온체인 배포 수를 확정할 수 없다. 근거: S3, S6, S7.
- 지갑/수탁/키관리 기능:** 구현 있음. DID 키는 서버에서 Ed25519로 생성하고 체인 지갑은 외부 계정 생성 API로 발급한다. DID 키와 지갑 키를 서버 파일에 저장하며 DID 키는 MySQL에도 저장한다. 일부 체인 요청에 서버 소유자 키를 사용하고, 레거시 지갑 회수 시 저장된 지갑 키를 불러온다. 실제 수탁 서비스 해당 여부와 운영 보관 유형은 기업 확인 필요. 근거: S2, S3, S7. 상세: 별첨 C.
- 주요 시스템 구성:** 테스트 웹(HTML/JavaScript) → Flask API → 외부 DChain HTTPS API로 연계하며, Flask는 MySQL과 로컬 DID/키 파일 저장소를 사용한다. Gunicorn/systemd 배포 예시가 있다. 실제 서버·DB·노드 수 및 네트

워크 구성은 기업 확인 필요. 근거: S1-S9. 상세: 별첨 A.

13. **클라우드 사용/사업자:** AWS EC2용 배포 예시가 저장소에 있다. 실제 AWS 사용 여부, 계정·리전·리소스 수 및 관리 주체는 기업 확인 필요. 근거: S8.

14. **노드 직접 운영:** 코드에서는 외부 DChain API 호출 방식을 확인했다. 직접 노드를 구동하는 설정은 저장소에서 미확인이다. 기업이 별도로 운영하는 노드의 유무·수·역할은 확인 필요. 근거: S4-S6.

15-22. 개인정보 및 관리체계

15. **개인정보 처리 여부:** 사용자 식별자, DID, 지갑주소 등 사용자 연계 데이터를 입력·저장하는 기능이 있다. 실제 개인정보 처리 여부와 범위는 실운영 데이터 및 다른 서비스와의 결합 관계를 확인해 확정해야 한다. 근거: S2, S7.

16. **처리 정보 유형:** DID, label/userIdentifier/id/user_id에서 받은 사용자 식별자, 계정 주소, 공개키·개인키, 생성시각, 영상별 토큰 지급 상태를 처리한다. VC 발급 요청의 claims는 임의 속성을 수용한다. DB에는 credential JWT·상태·유효기간 필드도 있으나 현재 로컬 VC 발급 라우트의 해당 DB 저장 호출은 확인되지 않는다. 이름·연락처·KYC·생체정보의 실수집 여부는 미확인이다. 개인키는 별도의 인증 비밀정보로 관리 대상이다. 근거: S2, S7.

17. **개인정보 처리방침:** 최신 방침 문서/URL은 저장소에서 미확인. 기업 보유 자료 확인 필요.

18. **만 14세 미만 대상 서비스:** 기업 확인 필요. 서비스 대상 연령과 법정대리인 동의 운영 내역은 코드로 확인할 수 없다.

19. **정보보호 정책/지침:** 승인된 정책·지침은 저장소에서 미확인. 기업 보유 문서명 확인 필요.

20. **최근 1년 취약점 점검:** 기관·일자·결과보고서는 미확인. 회수 API 테스트 코드는 있으나 취약점 점검 수행 증적에 해당한다고 단정할 수 없다. 근거: S10.

21. **ISMS/ISO27001 등 인증:** 기업 확인 필요. 인증명과 유효기간 증빙을 확인해야 한다.

22. **최근 3년 보안사고:** 기업 확인 필요. 코드만으로 사고 유무를 확정할 수 없다.

23-33. 블록체인 점검 자료

23. **블록체인 보안현황 조사서:** 별도 서식1이 제공되지 않아 공식 서식 작성은 미완료. 본 문서의 기능·키관리·API·확인 필요사항을 기초자료로 사용할 수 있다.

24. **점검 대상 목록:** Flask API, MySQL(DID/user/Token/keyValue), 로컬 DID/키 저장소, 외부 DChain 연계부, 소유자·사용자 지갑, 테스트 웹, EC2 서비스 설정을 후보 범위로 작성할 수 있다. 운영 URL, 컨트랙트·지갑 주소, 서버 수, 노드 운영 구분은 기업 확인 필요. 별첨 A 참고. 공식 서식2는 별도 필요.

25. **아키텍처·설계 문서:** 저장소 구현을 토대로 별첨 A에 구성과 온체인·오프체인 데이터 구분을 작성했다. 이는 이번 검토에서 작성한 구현 설명이며 기존 승인 설계 문서로 간주하지 않는다. 체인 내부 저장 구조와 실제 네트워크 분리는 확인 필요.

26. **불변식/파라미터 명세:** 자체 컨트랙트 명세는 미확인. 백엔드에서 확인되는 입력 제한·기본값·성공 판정 조건을 별첨 D에 정리했다. 온체인 불변식 및 설정 근거를 대신하지 않는다.

27. **스마트컨트랙트 소스코드:** 본 저장소는 Flask 연계 백엔드이며 자체 컨트랙트 소스·컴파일러·컨트랙트 lockfile·fork 출처는 미확인이다. 백엔드 검토 기준 커밋은 문서 첫머리에 명시했다. 자체 컨트랙트를 별도로 보유하면 해당 저장소와 빌드·테스트 지침을 추가해야 한다. 근거: S1, S11.

28. **배포 스크립트/설정:** 백엔드용 main/deploy/ec2/soh-did.service와 soh-did.env.example이 있다. 컨트랙트 배포 스크립트·배포 계획서·롤백 절차는 미확인이다. 설정 파일 제출 시 비밀값을 제거한 사본을 사용해야 한다. 상세: 별첨 D.

29. **권한 구조 문서:** 서버 소유자 계정·키 설정과 회수 API의 소유자 키 비교는 확인된다. 역할 기반 권한표, 다중서명 구성, 타임락, 권한 부여·회수 절차는 저장소에서 미확인이다. 별첨 C는 코드의 통제 현황이며 승인된 권한 정책이 아니다. 공식 서식6 및 운영 담당 직무별 매핑은 기업 확인 필요.

30. **업그레이드 절차:** 프록시 업그레이드 가능 컨트랙트와 단계별 승인·검증 절차는 미확인이다. 적용 여부부터 별도 확인 필요.
31. **외부 의존성:** DChain API, MySQL, 서버 로컬 파일 저장소와 Python 패키지에 의존한다. 코드의 장애 처리·대체 경로를 별첨 A에 작성했다. 실제 운영 주체·SLA와 공식 서식5는 별도 확인 필요.
32. **노드 설정 자료:** 노드 클라이언트·버전·P2P/RPC 공개 설정·노드/검증자 키 관리 설정은 저장소에서 미확인이다. 직접 운영 여부를 확인한 후 해당 시 별도 확보해야 한다.
33. **폐쇄형·자체 체인 자료:** genesis/chainspec, 참여 조직, 합의 구성, CA/MSP/채널 운영 자료는 저장소에서 미확인이다. 외부 체인의 실제 유형과 기업 운영 범위를 확인한 후 해당 여부를 정해야 한다.

34-45. 지갑·백엔드·운영 통제

34. **지갑 구성 자료:** 서버 소유자 지갑, DID 생성에 연계된 사용자 체인 지갑, DID/VC/VP 서명용 Ed25519 키를 구분할 수 있다. 보관·사용 경로는 별첨 C에 작성했다. 실제 주소, 핫/웜/콜드 구분, 중요도, 벤더 계약과 공식 서식7은 기업 확인 필요.
35. **키 관리 정책/절차:** 서버에서 Ed25519 키를 생성하고 로컬 JSON에 암호화 없이 저장하며 파일 권한 0600 설정을 시도한다. DID 개인키는 DB에도 저장한다. 체인 지갑 키는 외부 API에서 받아 같은 키 파일에 보관한다. 백업·복구·교체·입회·매체 완전삭제 절차는 미확인이다. /did/delete는 파일·인덱스를 삭제하지만 DB 키 삭제를 호출하지 않는다. 상세: 별첨 C.
36. **키 사용/서명 통제:** VC/VP 서명은 Flask 프로세스에서 수행한다. 체인 요청에는 개인키 필드를 DChain API로 전달한다. /token/retrieve는 요청의 송신자·수신자가 서버 소유자 주소와 일치하고 소유자 키가 일치해야 진행한다. 다른 라우트까지 이를 공통 적용하지는 않는다. MFA, 금액 한도, 목적지 허용목록, 다단계 승인, 별도 확인 채널은 저장소에서 미확인이다. 상세: 별첨 B-C.
37. **키 침해 대응:** 대응 정책·담당·연락망·긴급 자산 이전 절차·훈련 기록은 미확인이다. 배포 전 서비스라면 기업이 승인한 수립 계획이 필요하다.
38. **온체인 연계 백엔드:** API 목록, 전송·회수 흐름 및 실패 경로를 별첨 B에 작성했다. 입금 감지·확정 대기·중복 방지·재구성 롤백, 웹훅 검증 처리, 독립 체인 서명 서버는 이 저장소에서 미확인이다. 운영 시스템에 별도 구현이 있는지 확인해야 한다.
39. **관리자 콘솔:** 전용 관리자 콘솔, 로그인/MFA, 역할별 권한·계정 목록은 저장소에서 미확인이다. 테스트 웹을 운영 관리자 콘솔로 간주하지 않는다. 근거: S1, S9.
40. **프론트엔드/앱 및 서명 화면:** 테스트 웹은 http://127.0.0.1:5000의 DID 생성·목록·토큰 전송 API를 호출한다. 응답 JSON을 화면과 콘솔에 표시하며 별도의 서명 승인 화면은 미확인이다. 토큰명 예시 TOKEN_번호는 현재 서버 허용 목록과 불일치한다. 모바일 앱·개인키 저장 코드는 저장소에서 미확인이다. 실제 사용자 서비스 URL·RPC·주소 설정은 기업 확인 필요. 근거: S9, S7.
41. **온체인 모니터링:** 파일 로그와 일부 전송 실패 로그는 있으나 온체인 감시 주소·탐지 규칙·특권 함수 감시·알림 대응 체계는 저장소에서 미확인이다. 파일 로그 로테이션은 1MB, 백업 10개 설정이다. 근거: S1, S3.
42. **긴급 정지/사고 이력:** 코드에서 별도 출금 중지 스위치나 컨트랙트 pause 기능은 미확인이다. OS 서비스 중지는 가능하더라도 승인된 긴급정지 절차나 외부 체인의 정지를 의미하지 않는다. 실제 대응 절차·소요시간·사고 및 장애 이력은 기업 확인 필요.
43. **기존 감사/점검:** 감사 보고서·보안점검 결과·미조치 목록은 저장소에서 미확인이다. 테스트 코드와 본 문서는 감사 보고서를 대체하지 않는다.
44. **온체인 잔액/내부 원장 대사:** 잔액 조회 API와 로컬 사용자 토큰 상태 필드는 있으나 자동 대사·실행 기록·불일치 처리 절차는 미확인이다. increase_balance는 수량 누적이 아니라 지정 컬럼을 1로 설정한다. 회수 경로에는 해당 필드의 차감/초기화가 없다. 결제·정산 서비스 여부 및 별도 원장을 확인해야 한다. 근거: S3, S7.

45. **증적 표본:** 전체 요청·검토·승인·서명·전송·거래해시·원장 반영이 연결된 운영 표본은 이번 검토에서 검증하지 않았다. 테스트/샘플 파일을 실거래 증적으로 간주하지 않는다. 점검 수행사가 지정한 표본을 기업이 개인정보·비밀값을 가린 뒤 확보해야 한다.

46-51. 접근 환경 및 정보시스템

46. **점검 환경/접근권:** 저장소는 https://github.com/hanathomastone/SOH_DID이며 기준 커밋은 문서 첫머리에 명시했다. 읽기 전용 권한 부여, 테스트망/포크 환경 제공은 별도 협의 사항이다. 현재 코드에 민감한 기본 설정값이 있어 외부 제공 전 소스와 이력의 비밀정보 검토가 필요하다. 이번 작업에서는 접근권을 부여하지 않았다.

47. **자료반출 구분표:** 기업 승인 필요. 초안으로 코드 구조·API 목록·비밀값 제거 설정은 검토용 제출 후보, 개인키·API 토큰·DB 비밀번호 원문은 반출 제외 후보, 실제 개인정보·로그·주소 목록은 마스킹 또는 현장 열람 협의 대상으로 제안한다. 최종 반출 분류와 공식 서식3은 기업이 확정해야 한다.

48. **시스템 상세정보:** 확인 가능 기술은 Python/Flask, Gunicorn, MySQL(PyMySQL 1.1.1 동봉), Linux/systemd 기반 EC2 배포 예시이다. Server Windows/Linux 수량, DBMS 버전·수량, Apache/Nginx 등 웹 서버, 방화벽 /VPN/IDS/IPS/DDoS/WAF, 네트워크·가상화 장비, AWS 리소스의 실제 종류·버전·수량은 기업 확인 필요. 근거: S7-S8, S11.

49. **정보시스템 점검 스크립트 결과:** 점검용 스크립트와 가이드가 제공되지 않아 작성 불가. 운영 담당자가 대상 확정 후 실행 결과를 확보해야 한다.

50. **네트워크 장비 설정:** 장비 Config는 저장소에서 미확인. 운영 담당자 확인 및 비밀값 제거 사본이 필요하다.

51. **보안장비 사전 질의:** 별도 엑셀 질의 파일과 실제 장비 현황이 필요하다. 현재 소스만으로 작성할 수 없다.

별첨 A. 시스템·데이터·외부 의존성

A1. 코드에서 확인한 논리 구성

테스트 웹 → Flask API(/did, /token, /common) → DChain HTTPS API → 외부 체인 처리.

Flask API ↔ MySQL: DID/키/지갑주소, 사용자 식별자·상태, 토큰 메타데이터.

Flask API ↔ 로컬 파일: DID 문서, 개인키 파일, DID 인덱스. Flask API → 회전 로그 파일.

/mitum 접두 경로를 제거하는 미들웨어가 있어 /mitum/token/transfer 등의 요청도 같은 라우트로 연결된다. 별도 인증 경계가 아니다. 서버 수·망 분리·방화벽·리버스 프록시는 실제 구성 확인이 필요하다.

A2. 온체인/오프체인 데이터

- 온체인 처리 요청: 체인 계정 생성, 토큰 생성·전송·승인·발행·소각, 기본 통화 전송 등. 최종 온체인 기록 필드와 확정 규칙은 DChain 구현·응답 및 운영 증적으로 확인해야 한다.

- 오프체인 파일: dids/*.did.json, keys/*.key.json, index.json. DID 문서·생성시각·label·계정주소 및 DID/지갑 키를 저장한다.

- 오프체인 DB: DID 테이블의 DID/개인키/공개키/주소, user 테이블의 식별자·영상별 상태·credential 관련 필드, Token 테이블의 컨트랙트 주소·공급량·API 응답 메타데이터, keyValue 테이블.

- VC/VP: API 요청·응답에서 JWT를 처리한다. 현재 로컬 발급·생성 경로에 JWT 영구 저장 호출은 확인되지 않는다.

- DID 생성은 로컬 did:key 생성이며 DID 문서를 체인에 등록하는 호출은 이 경로에서 확인되지 않는다. 체인 지갑 생성과 구분한다.

A3. 외부 의존성 및 장애 영향

- DChain: 지갑 생성·토큰/체인 조회·변경 요청의 핵심 의존성. 응답이 잘못되면 주소·토큰 메타데이터 및 성공 판단에 영향을 준다. 기본 timeout 20초, timeout은 504, 연결/요청 오류는 502로 반환한다. 대체 API·자동 failover·거래 재시도 큐는 미확인이다. 실제 운영 사업자·자원체계는 별도 확인 필요.
- MySQL: DID/사용자/토큰 저장에 사용한다. 연결 재확인·재접속 처리가 있다. DID 저장 실패 시 DB 트랜잭션을 rollback하지만 이미 생성된 체인 지갑과 파일을 취소하지는 않는다. DB 복제·백업·대체 경로는 미확인이다.
- 로컬 디스크: 키가 없거나 잘못되면 DID/VC/VP 서명 및 레거시 회수에 영향을 준다. DID 인덱스는 임시 파일 교체와 프로세스 내부 lock을 사용한다. 여러 Unicorn 프로세스 간 동기화·공유 파일 운영 방안은 확인 필요.
- Python 라이브러리: Flask, flask-cors, gunicorn, requests, cryptography, PyJWT. requirements는 버전을 고정하지 않는다. PyMySQL 1.1.1은 vendor에 동봉되어 있다. 실제 설치 버전은 실행환경에서 별도 확인해야 한다.

별첨 B. API 목록과 자산 이동 흐름

B1. 등록된 API 목록

다음 목록은 소스의 라우트 등록을 정적으로 추출한 범위이다. /mitum 접두 경로도 지원한다.

- DID 생성: POST /did/create, /did/create_account, /did/signup.
- DID 관리: GET /did/dids; POST /did/resolve, /did/delete.
- VC/VP: POST /did/issue-vc, /did/verify-vc, /did/present-vp, /did/verify-vp.
- 토큰 변경: POST /token/create, /token/transfer, /token/approve, /token/transfer_from, /token/retrieve, /token/mint, /token/burn, /token/upload_token.
- 토큰 조회: POST /token/balance, /token/balance_list, /token/supply, /token/allowance; GET/POST /token/tokens, /token/token_list; GET /token/local_tokens.
- 공통 설정: GET /common/endpoints, /common/dchain_config.
- 체인 조회: GET/POST /common/node_info, /common/chain_id, /common/rpc_node, /common/block_number.
- 계정/블록/거래 조회: POST /common/acc_balance, /common/acc_info, /common/block_by_hash, /common/block_by_num, /common/trx_info, /common/trx_count.
- 계정/자산 변경: POST /common/acc_create, /common/acc_faucet, /common/cur_transfer.

B2. 토큰 전송 흐름과 실패 분기

요청 → token_name 정규화·허용 목록 검사(지정한 경우) → user_DID로 수신 주소 조회(지정한 경우) → 토큰 컨트랙트 조회(이름만 지정한 경우) → 송신자·키 기본값 보완 → DChain 요청 → HTTP 200 및 state=OK 확인 → DID와 token_name이 있으면 사용자 상태 컬럼을 1로 설정 → DB commit → 응답.

- 거부 조건: 허용되지 않은 token_name은 400, 찾을 수 없는 user_DID는 404, 이름으로 찾을 수 없는 컨트랙트는 400이다.
- 외부 전송 실패: 실패 로그를 남기고 외부 응답 또는 프록시 오류를 반환한다. 이 경우 로컬 상태 갱신은 하지 않는다.
- 외부 전송 성공 후 DB 실패: 외부 거래와 로컬 DB를 묶는 원자적 트랜잭션·보상 처리·재처리 기록은 미확인이다. DB 오류가 발생해도 외부 거래가 취소되는 것은 아니다.
- 상태 갱신은 전송 수량과 무관하게 1을 기록한다. 지급 완료 상태와 실제 잔액을 구분해야 한다.

B3. 회수 흐름과 실패 분기

POST /token/retrieve → 송신자/수신자 주소가 서버 소유자와 일치하는지 검사 + sender_pkey 비교 → 불일치 시 403 → holder의 로컬 지갑 키 탐색 → 키가 있으면 해당 계약·요청 수량에 대해 소유자 allowance 승인 → 승인 성공 시 transfer_from 호출 → 응답.

승인 실패 시 stage=approve 오류로 종료하며 transfer_from은 호출하지 않는다. 로컬 키를 찾지 못하면 추가 approve 없이 기존 transfer_from 프록시로 진행한다. 승인 성공 후 전송 실패 시 allowance 취소·보상 흐름은 확인되지 않는다. /token/transfer_from을 직접 호출하는 경로에는 /retrieve의 소유자 비교 분기가 적용되지 않는다. 실제 외부 검증 정책은 별도 확인 대상이다.

B4. 자산 이동 및 거래 유발 후보 경로

- 직접 이동 요청: /token/transfer, /token/transfer_from, /token/retrieve, /common/cur_transfer.
- 공급량·승인 변경: /token/create, /token/mint, /token/burn, /token/approve. retrieve 내부에서도 approve가 호출될 수 있다.
- 기타 체인 변경 후보: /common/acc_create, /common/acc_faucet, DID 생성 3개 별칭의 지갑 생성 호출, /token/upload_token. 실제 거래 생성 여부와 영향은 외부 API 구현에 따라 확인 필요.
- 입금 처리: 잔액·거래 조회 프록시는 있지만 입금 watcher, 확정 블록 수 기준, 중복 처리 키, 재구성 롤백 및 웹훅/콜백 검증 라우트는 미확인이다.

별첨 C. 키·지갑·권한 현황

C1. 용도별 키 인벤토리 초안

- DID 서명 키: Flask 프로세스에서 Ed25519PrivateKey.generate()로 생성. cryptography 라이브러리에 난수 생성을 위임하며 별도 엔트로피 장비·입회 기록은 미확인. DID 문서·VC·VP 기능에 사용한다. 개인키는 hex 문자열로 JSON과 DID 테이블에 저장한다.
- 사용자 체인 지갑 키: DChain /com/acc_create 응답에서 수신. DID 키 파일의 wallet 객체에 주소·공개키·개인키를 함께 저장한다. 레거시 회수의 allowance 승인에 사용한다. 외부 키 생성 환경과 알고리즘은 코드만으로 확인할 수 없다.
- 서버 소유자 체인 키: DCHAIN_OWNER_PRIVATE와 DCHAIN_OWNER_ADDR 설정을 사용한다. 토큰 생성·발행·전송의 기본값과 회수 인증에 관여한다. 기본 비밀값이 코드에 포함되어 있어 제출본에는 값을 실지 않았다.

C2. 저장·노출·삭제 동작

저장 경로는 DID_DATA_DIR → DATA_DIR → ./data 순으로 결정된다. 키 파일은 JSON 직렬화로 저장하고 파일 권한 0600을 시도하지만 실패를 무시한다. 실제 OS ACL, 디스크/DB 암호화, 백업 접근권은 별도 확인이 필요하다. HSM/KMS/MPC 연계는 이 저장소에서 확인되지 않는다.

DID 생성 성공 응답에는 DID 개인키와 체인 wallet 객체가 포함된다. 테스트 웹은 응답 전체를 화면과 콘솔에 출력하므로 키도 출력될 수 있다. 회수 API에서 키를 직접 반환하지 않는다는 사실을 전체 API의 키 비노출 정책으로 확대해서는 안 된다.

/did/delete는 DID 문서·키 파일·인덱스를 삭제한다. DB의 DID/user 행, 복제본·백업, 클라이언트에 전달한 키의 폐기를 처리하지 않는다. 파일 unlink는 매체 완전삭제의 증거가 아니다.

C3. 구현된 통제와 확인할 통제

- 공통 DChain 연계: 클라이언트가 넘긴 token/chain 대신 서버 설정을 사용한다. 이는 외부 서비스 호출 인증이며 앱 호출자의 로그인·업무 권한 확인을 의미하지 않는다.

- retrieve 전용 통제: 송신자·수신자 주소 비교 및 hmac.compare_digest를 이용한 소유자 키 비교. 다중서명/MFA/분리 승인에 해당하지 않는다.
- 기타 기능: Flask 등록 코드와 라우트에서 공통 사용자 인증·역할 기반 권한 검사는 미확인이다. API Gateway·네트워크·상위 서비스의 별도 통제는 기업 확인 필요.
- 체인 서명: 본 앱은 private key 필드를 외부 DChain으로 전송한다. 외부 서명 서버의 실제 구성·격리·권한은 미확인이다. 로컬 VC/VP 서명은 API 프로세스에서 실행한다.
- 로깅: 토큰 전송 실패 로그에 특정 private key 키명을 마스킹한다. 모든 로그·오류 응답·중첩 문자열의 비밀정보 제거가 보장된다고 볼 수 없다.
- 운영 절차: 키 생성 입회·백업·분산 보관·복구 시험·정기 교체·긴급 이전·폐기·승인 채널·담당 직무는 모두 기업 확인 필요.

별첨 D. 파라미터·배포·검증 범위

D1. 코드에서 확인한 조건과 기본값

- 체인 설정: 기본 DCHAIN_CHAIN_NAME=minic, 요청 timeout 20초. 운영 환경변수로 달라질 수 있다.
- 토큰 생성: decimals 미지정 시 9. token_name 정규화 실패를 즉시 거부하지 않고 외부 요청으로 진행하는 분기가 있다.
- 토큰 전송: token_name을 지정하면 ESSENTIAL_VIDEO_1-5 또는 OPTIONAL_VIDEO_1-7로 정규화·제한한다. user_DID가 있으면 amount 미지정 시 1을 사용한다. amount 양수·상한 등의 공통 검증은 이 라우트에서 미확인이다.
- 소유자 기본값: 생성·mint의 owner 및 전송의 sender/key는 setdefault 방식이다. 요청이 값을 지정하면 서버 기본값으로 강제 교체하지 않는다. token/chain의 강제 서버 설정과 구분해야 한다.
- VC/VP: VC 기본 TTL 3600초, VP 기본 TTL 300초. TTL을 정수 변환하며 명시적 허용 상한·양수 제한은 미확인이다. 검증은 EdDSA 및 필수 시간/발급자 클레임을 검사한다. VC audience 검사는 aud가 제공될 때, VP 검증은 aud 필수 조건으로 적용된다.
- 성공 조건: 토큰 생성 저장·전송 후 상태 갱신은 HTTP 200 및 body.state=OK를 사용한다. 독립적인 온체인 확정 확인 기준은 미확인이다.

D2. 배포 예시에서 확인된 값

Linux/systemd에서 ubuntu 사용자·www-data 그룹으로 Gunicorn을 실행한다. 작업 경로 예시는 /opt/soh-did/current, 환경파일은 /etc/soh-did/soh-did.env, 바인딩은 127.0.0.1:5000이다. Gunicorn은 workers 2, threads 4, timeout 60초이며 자동 재시작 설정이 있다. 실제 적용 여부는 미검증이다.

필요 설정 범주는 DCHAIN_BASE_URL/API_TOKEN/CHAIN_NAME/TIMEOUT/OWNER_ADDR/OWNER_PRIVATE, MYSQL_HOST/PORT/USER/PASSWORD/DATABASE, DID_DATA_DIR 또는 DATA_DIR, APP_LOG_DIR이다. 값은 운영 담당자가 안전한 경로로 제공해야 한다.

직접 run.py를 실행하면 0.0.0.0:5000, debug=True로 실행한다. 이것을 운영 배포 설정으로 간주하지 않는다. Python·MySQL·설치 패키지의 실제 버전, 리버스 프록시·TLS·접근 제어와 비밀값 제거 배포본은 별도 확인 필요.

D3. 이번 작성의 검증 범위

원본 PDF 3쪽과 항목 번호 1-51을 확인하고 라우트·저장 로직·배포 예시를 정적으로 검토했다. 운영 DB/체인 호출, 실제 거래, 운영 서버 점검과 보안 취약점 재현은 수행하지 않았다. 기존 main/tests/test_token_retrieve.py는 확인했지만 실행하지 않았다. 모듈 import 과정에서 DB 초기화가 발생할 수 있으므로 완전한 외부 의존성 격리를 먼저 마련해야 한다.

근거 파일 색인

다음 경로는 검토 기준 커밋의 저장소 루트 기준이다. 비밀값이 포함될 수 있는 파일은 원문을 그대로 외부 제출하지 않는다.

- S1: main/run.py, main/myapp/__init__.py - 앱 등록·미들웨어·로그·CORS·실행 설정.
- S2: main/myapp/routes/did.py - DID 생성·파일/DB 저장·VC/VP·삭제.
- S3: main/myapp/routes/token.py - 토큰 생성·전송·승인·회수·외부 프록시.
- S4: main/myapp/routes/common.py - 체인·계정·블록·거래 API.
- S5: main/myapp/dchain.py - 서버 인증 설정·HTTP 요청·오류 처리.
- S6: main/myapp/utlis.py - 외부 주소·체인·엔드포인트·환경변수. 민감한 기본값 포함.
- S7: main/myapp/mysql_db.py, DID_db.py, USER_db.py, Token_db.py 및 각 조회 모듈 - 스키마·데이터 저장/조회.
- S8: main/deploy/ec2/soh-did.service, soh-did.env.example - 배포 예시.
- S9: test_web.html, test_script.js - 테스트 화면·API 호출.
- S10: main/tests/test_token_retrieve.py - 회수 동작 테스트 코드.
- S11: main/requirements.txt, main/vendor/PyMySQL-1.1.1.dist-info/METADATA - 의존성 목록.

기업에서 보완할 정보

조직/담당/인원, 실제 서비스명·출시일·사용자 수·운영 단계, 연결 체인 유형, 운영 URL·서버/DB/노드/장비 수와 버전, 실제 지갑·컨트랙트 주소 목록, 개인정보 처리방침 및 대상 연령, 보안 정책·인증·점검·사고 이력, 키관리/권한/승인/모니터링/긴급정지/대사 절차와 운영 증적을 확인해야 한다. 원본에서 참조하는 서식1-2-3-5-6-7과 후속 정보시스템 점검 파일을 확보하면 본 작성안을 해당 서식으로 옮길 수 있다.